

Testes e Validação dos Serviços em Ambiente de QA

Introdução

Neste documento, apresentamos os procedimentos adotados para testar e validar os serviços de segurança implementados na arquitetura AWS do e-commerce da Nova Tech. Embora os testes tenham sido simulados, o processo foi descrito como se fossem realizados em um ambiente de QA, com o objetivo de assegurar que as configurações de segurança atendam aos requisitos técnicos e as melhores práticas da AWS.

Configuração do Ambiente

- **VPC:** Foi configurado as Subnets Públicas e Privadas em duas Zonas de Disponibilidade da região us-west (N. Virgínia). Também foram configurados dois NAT Gateway, o Internet Gateway e as tabelas de rota. Também foi configurado a VPN Site-To-Site. Configuração de ACLs.
 - **Observação** = Anteriormente foi estimado os custos na região N. Califórnia. Mas por conta da latência e custo, preferimos trocar para a região N. Virgínia
- **Instâncias EC2 e RDS:** Foram alocadas as instâncias EC2 para hospedar o e-commerce e instâncias do BD, para hospedar o RDS.
- **Security Groups:** As configurações de inbound e outbound foram definidas para as instâncias EC2.
- **Auto Scalling:** Configurações do Auto Scalling Group.
- **ELB:** Configurações do Application Load Balancing.
- **S3:** Foi configurado o S3 para o armazenamento estático de imagens e vídeos, registro de logs de monitoramento, armazenamento de backup e snapshots.
- **Outros Serviços:** CloudTrail, Config, WAF, GuardDuty, IAM, KMS, e AWS Systems Manager.
 - **CloudTrail:** Será responsável pelo registro das atividades e chamadas de API dentro do ambiente.
 - **Config:** Irá auditar, monitorar e avaliar as configurações dos recursos.
 - **WAF:** Irá proteger o e-commerce da Nova Tech de ataques comuns, como DDos.
 - **GuardDuty:** Irá detectar ameaças maliciosas dentro do ambiente.
 - **IAM:** Foi configurado os grupos de usuários e permissões.

- **KMS:** Foi configurado para gerenciar as chaves de criptografia para proteger os dados do RDS e S3 e dados em trânsito.
- **System Manager:** Foi configurado para o gerenciamento dos recursos e instâncias e automação e monitoramento.

Testes de Segurança

A seguir estão descritos os principais testes de segurança realizados para garantir a segurança do ambiente e do e-commerce.

Teste do Security Group e ACLs

- **Objetivo:** Garantir que o tráfego de entrada para a aplicação e o banco seja devidamente controlado.
- **Procedimento:**
 - Foi simulado tentativas de acesso não autorizadas diretamente nas instâncias EC2 e RDS, como por exemplo o SSH.
 - Foi verificado as regras de segurança do Security Group e ACLs.
- **Validação:**
 - Apenas o tráfego de entrada HTTP/HTTPS teve sucesso. As requisições chegaram ao **Application Load Balancer** (ALB) e foram direcionadas para a instância EC2.
 - O acesso ao banco de dados pela internet foi negado. O acesso ao banco de dados só é possível internamente, através do **AWS Systems Manager**.

Teste de proteção contra ataques com WAF

- **Objetivo:** testar eficiência do WAF contra ataques comuns, como por exemplo injeção de SQL.
- **Procedimento:**
 - Foi realizado teste de injeção de SQL para manipular o banco de dados.
 - O WAF foi configurado para bloquear tráfego malicioso e enviar logs ao bucket no S3.

- **Validação:**
 - O WAF bloqueou as tentativas de injeção de SQL e enviou os registros ao S3.

Teste de Monitoramento e Auditoria com CloudTrail e AWS Config

- **Objetivo:** validar se as ações realizadas no ambiente estão sendo monitoradas e registradas.
- **Procedimento:**
 - Foram realizadas mudanças nas configurações e criação de recursos.
 - O Config foi configurado para emitir alertas aos administradores em caso alguma configuração esteja fora da conformidade.
- **Validação:** Foi verificado os logs gerados pelo CloudTrail e os alertas emitidos pelo Config.

Teste de Detecção de Ameaças com GuardDuty

- **Objetivo:** Verificar se o **GuardDuty** detecta atividades anômalas e possíveis ameaças de segurança.
- **Procedimento:**
 - Simulamos tentativas de acessos indevidos, como por exemplo o acesso SSH as instâncias que hospedam o e-commerce.
- **Validação:** GuardDuty detectou o acesso suspeito e relatou no painel as ameaças.

Teste de Criptografia e Gerenciamento de Senhas

- **Objetivo:** Validar a criptografia de dados, bem como o gerenciamento de segredos com o **KMS** e **Secrets Manager**.
- **Procedimento:**
 - Foram criadas chaves KMS para criptografar dados no S3 e RDS, como por exemplo os dados de acesso do BD.
- **Validação:** Os dados foram criptografados corretamente, e as chaves foram gerenciadas com sucesso. O Secrets Manager garantiu que segredos não fossem expostos indevidamente.

Resultados e Conclusões

Os testes realizados demonstraram que a infraestrutura de segurança implementada no ambiente AWS cumpre os requisitos estabelecidos, garantindo a proteção contra ameaças e a conformidade com padrões de segurança. Todas as funcionalidades foram validadas com sucesso no ambiente de QA, fornecendo confiança para a implantação futura do e-commerce da Nova Tech em ambiente de produção.